

CodeMender: Autonomous AI Application Security

Vulnerability Discovery, Keyless WIF Auth &
Automated Remediation in CI/CD

Executive Overview & Problem Statement

- Problem: Legacy SAST scanners produce high false-positive rates and alert fatigue
- Problem: Developers waste hours manually triaging and writing security patches
- Solution: CodeMender acts as an autonomous AI Security Engineer in your CI/CD pipeline
- Solution: Discovers vulnerabilities, proves exploitability, and opens automated fix PRs

CI/CD Architecture Workflow

- 1. Developer Push: Code push to GitHub main branch triggers CI/CD pipeline
- 2. Keyless Auth: Workflow authenticates to GCP via Workload Identity Federation (WIF)
- 3. AI Discovery: Standalone CLI (cm find) scans codebase using Vertex AI (gemini-3.8-flash)
- 4. Security Upload: Findings exported as SARIF 2.1.0 to GitHub Code Scanning hub
- 5. Formal Verification: cm verify synthesizes exploits and validates against

Key Architecture & Security Components

- Workload Identity Federation (WIF): Short-lived keyless OIDC auth (Zero long-lived keys)
- CodeMender Standalone CLI (cm): Statically linked Go binary embedded in runner environment
- Vertex AI LLM Engine: Multi-step threat modeling powered by gemini-3.8-flash model
- GitHub Security Dashboard: Native SARIF 2.1.0 integration for enterprise compliance
- Pytest Verification Suite: Guarantees 0 regressions by running unit tests

Automated Verification & Remediation Engine

- 100% Exploit Verification: Synthesizes PoC HTTP payloads to confirm vulnerability
- Context-Aware Patching: Replaces string-concatenated SQL with parameterized queries
- Safe Command Execution: Replaces `os.system()` with subprocess array execution
- Automated Regression Checks: Validates that code functionality remains intact post-fix

Business Value & Customer Impact

- 90%+ Reduction in Triage Time: Automated verification filters out non-exploitable noise
- Accelerated Developer Velocity: Developers receive ready-to-merge PRs instead of bug tickets
- Enterprise Governance: Complete audit trail, SARIF compliance, and keyless GCP IAM security
- Continuous Protection: Zero-delay security checks on every code commit